

Final Project: Part 1 - Perform Vulnerability Analysis and Penetration Testing

In this final project, you will demonstrate your ability to protect SecureBank from vulnerabilities and enhance its security posture.

Part 1 will consist of three tasks:

- **Task 1:** Identifying a vulnerability using IBM X-Force Exchange
- **Task 2:** Investigating the chosen vulnerability using Google Dorking
- **Task 3:** Creating a penetration testing plan

You will first provide screenshots that identify a vulnerability using IBM X-Force Exchange and investigate it further using Google Dorking. Next, you will make decisions that influence the outcome of the penetration testing plan. You should plan to complete Part 1 in about 30 minutes.

Step-by-step instructions

Refresh your knowledge

Before starting on the project or while doing the project, you can refresh your knowledge by referring to the following lessons:

- Module 1, Lesson 1: Penetration Testing: Planning Phase
- Module 1, Lesson 2: Penetration Testing: Discovery Phase
- Module 2, Lesson 1: Penetration Testing: Attack Phase
- Module 3, Lesson 2: Penetration Testing Reporting
- Module 4, Lesson 1: Threat Hunting and Intelligence

Project scenario

Imagine you've recently been hired as an ethical hacker by SecureBank, a mid-sized financial institution known for its rapidly growing digital services. In the wake of recent incidents in the banking sector, the management has become increasingly anxious about potential vulnerabilities in SecureBank's online banking platform. Preliminary investigations have highlighted weak security measures. To address these risks, the bank has tasked you with identifying vulnerabilities and investigating potential threats.

Setting up the system

Before you begin, you must have the following:

- A tool or application to capture screenshots

Guidelines for screenshots

Follow the below guidelines for capturing screenshots:

- Use an application, such as Snipping Tool, to capture screenshots.
- Perform the tasks and capture the corresponding screenshot(s).
- Confirm that the screenshot clearly displays the result of your activity. It's recommended that you set your system display resolution to the highest available setting.
- Upload the screenshot for each task or step to the specified area on the platform.

Completing project tasks

Submitting a complete assignment by adhering to the instructions will facilitate a thorough review.

For successful project submission:

- **Task 1:**
 - Complete the task and upload the required screenshot to the platform.
- **Task 2:**
 - Complete the three steps in this task and upload the corresponding screenshot for each step to the platform.
- **Task 3:**
 - Go through the six scenario-based questions and type the response that best suits the scenario in the designated area for each step. Then, provide a 1–2 line justification for your selection in the space provided.

Task 1: Identify a vulnerability using IBM X-Force Exchange

Your first task will be to identify any vulnerabilities that might expose the bank's systems to cyber threats. You will use IBM X-Force Exchange to gather threat intelligence.

The following are the steps to complete this task:

1. Visit <https://exchange.xforce.ibmcloud.com/>.
2. **Note:** You would have created a login in IBM X-Force Exchange when you worked on the corresponding lab.
3. Use the search bar to find a recent vulnerability that has been assigned a common vulnerabilities and exposures (CVE) number.

Submission: Capture a screenshot of the recently identified vulnerability. Ensure that the CVE number is visible.

Task 2: Investigate the selected vulnerability using Google Dorking commands

Your second task will be to further investigate the identified vulnerability using Google Dorking commands. You will use specific search queries to uncover any exposed or publicly available sensitive information that could potentially compromise the bank's systems.

Here are the steps to use **Google Dorking commands** for investigating your **selected vulnerability**:

Step 1: Use the "site" command to find information specific to your CVE number

- **Hint:** site: CVE-2024-XXXX
- **Submission:** Capture a screenshot of the search results and upload it to the designated area. Ensure that the search command and CVE number are visible in the screenshot.

Step 2: Refine the "site" command to limit the results to gov websites

- **Hint:** site: gov CVE-2024-XXXX
- **Submission:** Capture a screenshot of the search results and upload it to the designated area. Ensure that the search command, CVE numbers, and .gov sites are all included in the screenshot.

Step 3: Use the "filetype" command to find any PDF formatted reports related to the selected vulnerability

- **Hint:** site: gov CVE-2024-XXXX filetype: pdf
- **Submission:** Capture a screenshot of the identified PDF formatted vulnerability report on a .gov website and upload it to the designated area. Ensure that the CVE number, .gov site, and the PDF file are visible in the screenshot.

Task 3: Create a penetration testing plan

Scenario: SecureBank's management wants you to conduct a penetration test on their network. Once you have identified the vulnerabilities, you will need to create a penetration testing plan. This plan will outline your strategy for simulating cyberattacks to test the network's defenses and detect weak points. In this task, you will make decisions that will affect the outcome of the penetration test.

This task consists of six steps, each with **three options**. You need to **select the correct option based on the scenarios** and provide a **justification** in the designated space.

Step 1

Scenario: You are in a meeting with SecureBank's IT team to discuss the penetration test. The team includes the IT manager, the network administrator, and a security officer. They provide you with an overview of their infrastructure, which includes external web applications, internal databases, and a mix of on-premises and cloud-based services.

Question: What should you include in the scope?

Options:

- A: Include all systems, networks, and applications
- B: Focus only on the external-facing systems and applications
- C: Include only the internal network and critical applications

Step 2

Scenario: You are required to define the primary objectives of the penetration test. The IT team has expressed concerns about recent phishing attacks and regulatory compliance requirements.

Question: Which objective should be prioritized for the penetration test based on the IT team's concerns?

Options:

- A: Identify all possible vulnerabilities
- B: Test incident response capabilities
- C: Focus on compliance with industry standards

Step 3

Scenario: You have to establish the rules of engagement for the penetration test. However, the IT team is concerned about potential disruptions to business operations.

Question: What approach will you take to minimize disruptions while conducting the penetration test?

Options:

- A: Notify staff that the test will be conducted during business hours
- B: Notify staff that the test will be conducted after business hours
- C: Conduct the test without notifying the IT team

Step 4

Scenario: You begin the Discovery phase to gather information about the target systems. However, the IT team has provided you with limited information about their network topology.

Question: Which approach will be most effective for gathering information?

Options:

- A: Use automated tools like Nmap and Nessus
- B: Use manual techniques like social engineering
- C: Use a combination of automated and manual techniques

Step 5

Scenario: You have identified several vulnerabilities and are ready to exploit them. The vulnerabilities include an outdated web server, weak passwords, and an unpatched database.

Question: Which approach will you take to exploit the identified vulnerabilities?

Options:

A: Exploit the easiest vulnerabilities first

B: Exploit the highest severity vulnerabilities first

C: Exploit a mix of high-severity and easy vulnerabilities

Step 6

Scenario: You now have to compile your findings and provide recommendations. Your audience includes technical staff and the executive leadership.

Question: What is the most effective way to present your findings?

Options:

A: Create a detailed technical report

B: Create a high-level executive summary

C: Create a detailed technical report and an executive summary

Review criteria

Your grade will be based on the following distribution:

Task 1: Identify a vulnerability using IBM X-Force Exchange

Submission required: Screenshot from IBM X-Force Exchange, which includes the CVE number of a recent vulnerability.

Task 2: Investigate the selected vulnerability using Google Dorking commands

Submissions required:

- **Step 1:** Screenshot displaying the correct Google Dorking search command and results relating to the selected vulnerability, with the CVE number.
- **Step 2:** Screenshot displaying the correct Google Dorking search command, CVE number, and .gov sites.
- **Step 3:** Screenshot displaying the correct Google Dorking search command, CVE number, .gov site, and PDF file.

Task 3: Create a penetration testing plan

Submissions required: In the text box provided for each step:

Enter the best answer for the scenario-based question and provide a justification based on the scenarios for your selected option.

- **Step 1:** Identifies the items to be included in the penetration test scope.
- **Step 2:** Identifies the objective to be prioritized for the penetration test based on the IT team's concerns.
- **Step 3:** Identifies the approach to minimize disruptions during the penetration test.
- **Step 4:** Identifies the most effective approach for gathering information.
- **Step 5:** Identifies the approach to exploit the identified vulnerabilities.
- **Step 6:** Identifies the most effective way to present the findings.

Submitting your project

Before you submit the project, ensure to complete Part 2. Check your submissions thoroughly, and ensure they are ready for review.

Author

Dee Dee Collette

Other contributor(s)

Sharon Felix



Skills Network